계정 권한 비교 검증 보고서

초급자용 · 고도화 1·2 적용 후 재검사 · 2026년 10월 18일

Burp Workbench를 0.43.0에서 0.44.0으로 개선하고, 같은 실습 사이트 3.10.0의 50개 업무 기능을 다시 검사했습니다. 권한표와 차단 규칙, 쓰기 전후 조회를 설정한 조건끼리 비교합니다.

이번에 달라진 결과

평가 항목	개선 전 0.43.0	개선 후 0.44.0
실제 문제를 찾아냄 · 정탐	392건	392건
문제가 없는데 경고함 · 오탐	21건	0건
실제 문제를 놓침 · 미탐	0건	0건
추가 확인이 필요함 · 보류	623건	91건
경고 중 실제 문제 비율 · 정밀도	94.9%	100.0%

이번 설정 조건에서는 실제 권한 위반 392건을 계속 찾아내면서, 오탐 21건을 줄였습니다. 보류는 532건 줄었습니다. 이 수치는 같은 실습 대조를 반복해 얻은 측정값이며 운영 사이트 전체의 성능 확률이 아닙니다.

적용한 두 가지 개선

1. 정상 응답이 CSV나 파일이어도 대상 응답의 JSON 오류를 별도로 검사합니다. 거부 오류와 실제 자료가 함께 있으면 보류합니다.

2. 쓰기 요청에서 변경 없음, 지연 처리, 기대 상태 미도달, 조회 실패를 구분합니다. 명시적 차단 응답과 지정 항목의 변경 없음을 함께 확인한 경우에는 차단 근거를 유지합니다.

읽는 순서: 2쪽 검사 방법 / 3쪽 전체 수치 / 4쪽 정탐·오탐 / 5쪽 미탐 / 6쪽 보류 / 7쪽 새 사유 표시 / 8쪽 검증 범위 / 9~11쪽 전체 기능

2 검사 방법과 숫자의 의미

인증은 “누구인지”, 인가는 “이 자료를 보거나 이 작업을 해도 되는지”를 확인하는 과정입니다. 이 검사는 같은 기능을 다른 계정으로 실행해 업무 권한이 지켜지는지 확인합니다.

계정	검사하는 상황
관리자 admin	운영 기능과 개인 전용 자료의 권한을 구분합니다. 관리자에게도 금지된 기능이 있습니다.
Alice와 Bob	같은 일반 사용자여도 자료 소유자나 소속이 다르면 거부되는지 확인합니다.
비로그인	로그인 정보를 보내지 않고 공개 자료와 회원 전용 기능을 구분합니다.

세션 Cookie, X-Auth-Token, JWT Bearer를 단독 또는 함께 보내는 7가지 조합으로 반복했습니다. 복합 조합은 같은 로그인 묶음의 값을 요구하며, 별도 인증 수단을 쓰는 다중 요소 인증을 의미하지 않습니다.

검사 단위	계산과 뜻
50개 업무 기능	조회 23개와 작성·변경·삭제 27개입니다.
1400개 비교 기록	50개 × 인증 7가지 × 정상/취약 경로 2가지 × 설정 2가지
4200개 계정 대조	각 기록의 네 계정 중 기준 계정을 제외한 세 계정: 1400 × 3
설정별 2100개	설정 전과 설정 후를 나누어 평가합니다. 성능 표의 분모입니다.
별도 HTTP 2800개	50개 × 인증 7가지 × 경로 2가지 × 계정 4가지의 독립 검사입니다.

fixed 정상 경로는 허용 계정만 실행하고, vuln 취약 경로는 로그인과 요청 위조 방지(CSRF)를 유지한 채 업무 권한 검사만 생략합니다. 기준 계정은 정상 응답을 제공하는 역할이므로 성능 계산에서 제외합니다.

정답은 별도 권한표와 실제 관측으로 정했습니다. 읽기는 비공개 자료 표식의 반환을, 쓰기는 저장 버전과 처리 횟수 증가 및 마지막 실행 계정을 확인합니다. HTTP 200이나 403만으로 정답을 만들지 않았습니다.

3 개선 전후의 전체 결과

각 열은 2100개 계정 대조입니다. 설정 후에는 기대 권한표, 차단 응답 규칙과 쓰기 전후 조회를 추가합니다. 설정 전에도 계정 지정·SCOPE·쓰기 요청 허용은 준비되어 있습니다.

계정 대조 평가	이전 설정 후	개선 설정 후	개선 설정 전
정탐 TP	392	392	0
오탐 FP	21	0	0
미탐 FN	0	0	392
위반도 경고도 없음 TN	1,687	1,708	1,708
보류 REVIEW	623	91	1,316
정밀도	94.9%	100.0%	경고 없음
재현율	100.0%	100.0%	0.0%

정밀도는 경고 중 실제 문제의 비율이고, 재현율은 실제 문제 중 찾아낸 비율입니다. 보류는 TP·FP·TN·FN과 별도로 더하는 다섯 번째 집계가 아닙니다. 실제 위반을 보류했다면 엄격한 재현율에서는 미탐으로 셉니다.

TN은 실제 위반이 없는 대조에서 잘못된 우회 의심 경고가 없었다는 뜻입니다. 보류 결과도 TN에 포함될 수 있으므로 TN 전체를 “안전 확정”으로 읽으면 안 됩니다.

개선 후 · 설정한 조건의 계정별 결과

계정	정탐	오탐	미탐	보류
관리자	56	0	0	7
Alice	154	0	0	42
Bob	182	0	0	42
비로그인	0	0	0	0

비로그인에는 실제 권한 위반의 양성 사례가 없었습니다. 이 결과로 비로그인 취약점 탐지 능력이 100%라고 주장할 수 없습니다. 같은 서버와 공통 처리 코드를 인증 방식별로 반복한 결과입니다.

4 정탐과 오탐의 사유

정탐 392건: 금지된 계정의 실제 접근을 경고함

유형	관측한 정답 근거	건수
자료 조회	권한표는 DENY인데 비공개 자료 표식이 응답에 반환됐고, 확장이 우회 의심으로 경고했습니다.	154
작성·변경·삭제	권한표는 DENY인데 독립 전후 조회에서 버전·처리 횟수 증가와 실행 계정을 확인했고, 확장이 경고했습니다.	238

예: 7번 Alice 비공개 글은 관리자와 Alice만 허용됩니다. 취약 경로에서 Bob에게 AUTH50_PRIVATE_7 자료가 반환되어 정탐이 됩니다. 같은 조건을 인증 7가지로 반복하면 정탐 7건으로 셉니다.

오탐 21건 → 0건: 응답 형식이 달라도 오류 검사

이전에는 기준 응답이 CSV·파일이면, 대상 응답이 JSON 거부 오류여도 두 응답을 JSON으로 함께 비교할 수 없다는 이유로 검사를 건너뛰었습니다. 이후 권한표의 DENY와 HTTP 200이 결합해 잘못된 우회 의심 경고가 됐습니다.

이전 오탐 대상	실제 응답과 개선 후 근거
18번 개인정보 내보내기 관리자·Bob · 14건	정상 자료는 CSV입니다. 거부 시 HTTP 200과 error=FORBIDDEN만 반환하고 개인정보는 없습니다. 개선 후 대상 JSON의 정확한 오류 경로·값을 검사합니다.
42번 비공개 파일 Alice · 7건	정상 자료는 일반 파일입니다. 거부 JSON의 오류를 독립적으로 확인해 잘못된 경고를 없앴습니다.

오류 문자열을 아무 위치에서 찾는 방식은 아닙니다. 설정한 JSON 경로와 값이 맞아야 합니다. 오류와 data·content 등 자료 또는 설정한 중요 필드가 함께 있으면 “차단 응답과 데이터 충돌”로 보류합니다.

5 미탐의 사유와 반드시 필요한 설정

설정 후 미탐 0건

개선 후 권한표와 전후 조회를 설정한 조건에서는 실제 권한 위반을 놓친 사례가 관측되지 않았습니다. 미탐 0건에 대한 개별 사유를 만들어 쓰지 않습니다. 이번 데이터에 없는 업무나 지연·동시 처리까지 검증했다는 뜻도 아닙니다.

설정 전에는 여전히 미탐 392건

미탐 형태	건수	사유
보류하여 경고하지 않음	385	접근 권한표가 없으면 공개·공유 허용과 권한 위반을 구분하기 어렵습니다. 쓰기는 응답만으로 실제 저장 변경을 확인할 수 없습니다.
차단으로 잘못 판단	7	HTTP 403 거부 응답 뒤 실제 저장 변경이 일어났습니다. 전후 조회를 설정하지 않아 응답의 차단 표시만 보게 됐습니다.

50번 Bob 문의 완료: 403인데 실제 처리됨

이 기능은 관리자와 Bob만 허용합니다. 취약 경로에서 Alice로 실행하면 HTTP 403과 거부 메시지를 반환하지만, 독립 조회에서는 저장 버전과 처리 횟수가 각각 1 증가하고 마지막 처리자가 Alice로 바뀝니다.

문의 상태명은 이미 CLOSED인 경우가 있어 실행 전후에 그대로일 수 있습니다. “열림이 닫힘으로 바뀌었다”라고 설명하면 실제 근거와 다릅니다. 이 검사는 저장 버전과 처리 이력도 확인해 같은 상태의 재처리를 탐지했습니다.

설정 전	설정 후
403 응답을 차단으로 보아 7개 인증 조합에서 미탐	처리 전후 버전 증가를 관측해 7건 모두 우회 의심으로 탐지

이번 개선은 필요한 설정을 자동으로 추측하는 기능이 아닙니다. 실제 서비스의 허용 계정과 완료를 확인할 조회 항목을 정확히 지정해야 합니다. 관측된 변경이 해당 요청의 결과인지는 재현과 업무 기록으로 확인합니다.

6 보류의 사유와 감소한 이유

설정 후 보류는 623건에서 91건으로 줄었습니다. 이전 쓰기 보류 616건 중 명시적 거부 응답과 지정 항목의 변경 없음을 함께 확인한 경우에는 차단 근거를 유지합니다. 변화가 없다는 사실 하나만으로 차단을 확정하지 않습니다.

남은 보류	건수	사유
HTTP 302	7	이동 응답의 위치와 로그인·업무 결과를 확인해야 함
HTTP 404	63	쓰기 후 지정 항목은 미변경이지만, 자료 없음/삭제 응답만으로 정상 차단을 확정할 수 없음
HTTP 410	21	쓰기 후 지정 항목은 미변경이지만, 자료 없음/삭제 응답만으로 정상 차단을 확정할 수 없음

이 보류 대조는 독립 검사에서 실제 권한 위반이 없었지만, 확장이 가진 응답과 지정 항목 관측만으로 결론을 확정할 수 없어 남겼습니다. 보류를 줄이는 것 자체보다 근거 없이 초록으로 바꾸지 않는 것이 중요합니다.

차단 근거를 유지하는 조건

계정별 기대 권한이 DENY이고, HTTP 401/403 또는 설정한 거부 규칙이 명시적으로 맞으며, 준비된 전후 조회에서 지정 항목이 변하지 않았을 때입니다. 보고서와 화면에는 조회 횟수와 관측 범위의 한계를 함께 남깁니다.

계속 보류하는 조건

HTTP 202로 접수만 된 경우, 기대 완료 값에 도달하지 않은 경우, 후속 조회 실패, 차단과 자료 필드의 충돌, 전후 조회 준비 실패를 구분합니다. 404/410이나 즉시 미변경만으로 지연 작업과 모든 부작용이 없다고 결론내리지 않습니다.

새 경계 조건은 별도 회귀 테스트로 확인했습니다. 50개 업무 기능 재측정에서 지연 처리·조회 실패·자료 충돌이 실제로 발생했다고 합산하지 않습니다.

7 화면에서 확인할 새 판정 사유

기존 종합 판정과 색상을 유지하면서 상세 근거의 사유를 구체화했습니다. 아래 사유는 모두 노란색 보류입니다. 경고가 없다는 사실과 안전 확정은 구분합니다.

표시 사유	뜻과 다음 확인
차단 응답과 데이터 충돌	거부 표시와 자료가 함께 있습니다. 실제 비공개 내용이 노출됐는지 확인합니다.
쓰기 검증 미설정	응답은 성공처럼 보이지만 실제 처리 근거가 없습니다. 전후 조회를 설정합니다.
처리 결과 미확인	지정 항목이 변하지 않았습니다. 완료를 확인할 항목·업무 조건·명시적 거부 근거를 점검합니다.
지연 처리 확인 필요	HTTP 202 접수 후 즉시 완료되지 않았습니다. 작업 상태와 최종 결과를 별도로 확인합니다.
기대 상태 미도달	조회 값은 변했지만 기대한 완료 값과 다릅니다. 부분 처리 또는 다른 변경을 확인합니다.
후속 조회 실패	쓰기 이후 상태 조회가 실패했습니다. 실제 처리 여부를 다시 조회합니다.
전후 조회 준비 실패	처리 전 상태가 이미 완료됐거나 조회에 문제가 있습니다. 대상 쓰기는 보내지 않고 준비를 점검합니다.

초급자가 남길 최소 근거

기능·사용 계정·기대 권한·실제 응답·자료 노출 또는 저장 변경·최종 판단 사유를 함께 적습니다. “Bob에게 금지된 Alice 글이 반환되어 정탐”, “HTTP 200이지만 거부 JSON만 있어 이전 오탐 해소”처럼 기대와 관측을 연결하면 됩니다.

쓰기 요청을 자동으로 반복하거나 되돌리지 않습니다. 설정한 후속 GET 조회만 최대 3회 실행하며 두 번째 조회부터 500ms 간격을 둡니다. 이번 50개 기능 측정은 기존과 동일하게 1회 조회 조건을 사용했습니다.

8 이번 검증의 범위와 근거

이번 실행	확인한 내용
회귀 검사	신규 응답·쓰기 사유 회귀 39개를 포함한 정식 빌드 검사를 실행했습니다. 정확한 분류 경계와 기존 기능 회귀를 확인했습니다.
실제 Burp 비교	Burp Burp Suite Community Edition 2026 3.3에 확장 0.44.0을 불러와 실제 Montoya HTTP로 1400개 기록·4200개 계정 대조를 실행했습니다.
독립 정답 확인	별도 HTTP 2800개, 잘못된 인증 조합 33개, 계정 신원 검사 21개와 쓰기 전후 독립 조회를 확인했습니다.
격리 환경	임시 Burp 프로필과 loopback 서버, H2의 Oracle 호환 모드를 사용했습니다. 사용자 Burp 설정을 바꾸지 않았습니다.

동일한 기능·권한표·인증 조합·정상/취약 경로·설정·처리 지연 조건으로 이전 원본 근거와 연결해 비교했습니다. 각 계정 대조의 판정 사유, 독립 정답 근거와 보류 이유는 CSV에 모두 기록했습니다.

이번 결과의 한계

같은 실습 서버와 공통 처리 코드를 반복했습니다. 서로 다른 운영 서비스에서 얻은 독립 표본이 아니므로 이번 정밀도·재현율을 운영 탐지 확률로 일반화할 수 없습니다. 실제 Burp GUI 클릭·Windows DPI·한글 입력, 외부 OAuth·OIDC·SAML, 실제 Oracle/Nginx 배포는 이번 고도화에서 다시 실행하지 않았습니다. 이전 검증 기록은 별도 자료입니다.

JSON 검사는 크기·구조 한도 안에서 수행합니다. 자료 충돌 검사는 흔한 자료 필드와 지정한 소유/중요 필드에 대한 보수적 방어이며 모든 응답 스키마의 정보 노출을 증명하지 않습니다. 지정 항목 미변경은 다른 필드나 지연된 부작용의 부재를 증명하지 않습니다.

상세 근거 파일

함께 제공한 상세 근거 ZIP에서 아래 파일을 확인할 수 있습니다.

기대 권한표: expected-policy.csv

계정별 판정과 보류 사유: analysis/account-results.csv

이전 대비 변화: analysis/comparison.json

회귀 검사 집계: analysis/release-check-summary.json

실제 Burp 실행 기록: raw/summary.json

9 전체 기능 결과 · 1번부터 17번

개선 후 설정 조건의 계정별 대조입니다. 전체 오탐·미탐은 모두 0건이므로 표에는 정탐·보류를 표시합니다. 정탐의 근거는 읽기에서 자료 반환, 쓰기에서 저장 변경입니다.

번호	기능	허용 계정	정탐	보류	보류 HTTP: 건수
1	공개 게시글 목록	모두	0	0	-
2	공지사항 조회	모두	0	0	-
3	공개 도움말 조회	모두	0	0	-
4	공개 주제 검색	모두	0	0	-
5	회원 디렉터리 조회	로그인 계정	0	0	-
6	게시글 작성	로그인 계정	0	0	-
7	Alice 비공개 글 조회	관리자, Alice	7	0	-
8	Alice 임시 글 편집	관리자, Alice	7	7	404: 7
9	Bob 게시글 삭제	관리자, Bob	7	7	410: 7
10	신고 게시글 숨김	관리자	14	0	-
11	Bob 비공개 댓글 조회	관리자, Bob	7	0	-
12	Alice 댓글 편집	관리자, Alice	7	0	-
13	Bob 댓글 삭제	관리자, Bob	7	0	-
14	토론 상단 고정	관리자	14	14	404: 14
15	Alice 글 수정 이력 조회	관리자, Alice	7	0	-
16	Alice 비공개 프로필 조회	관리자, Alice	7	0	-
17	Bob 연락처 변경	관리자, Bob	7	0	-

허용 계정의 “모두”는 비로그인까지, “로그인 계정”은 관리자·Alice·Bob을 뜻합니다. 보류 404/410은 존재·삭제와 정상 차단의 구분이 불충분한 쓰기, 302는 이동 응답 확인이 필요한 조회입니다.

10 전체 기능 결과 · 18번부터 34번

개선 후 설정 조건의 계정별 대조입니다. 전체 오탐·미탐은 모두 0건이므로 표에는 정탐·보류를 표시합니다. 정탐의 근거는 읽기에서 자료 반환, 쓰기에서 저장 변경입니다.

번호	기능	허용 계정	정탐	보류	보류 HTTP: 건수
18	Alice 개인정보 내보내기	Alice	14	0	-
19	Bob 등록 기기 해제	Bob	14	0	-
20	Alice API 키 재발급	Alice	14	14	404: 14
21	Bob 알림함 조회	Bob	14	0	-
22	Alice 알림 읽음 처리	Alice	14	0	-
23	Bob 저장 검색 삭제	Bob	14	0	-
24	Alice 보안 이력 조회	Alice	14	0	-
25	사용자 이용 제한	관리자	14	0	-
26	공개 강의 목록	모두	0	0	-
27	팀 A 강의 자료 조회	관리자, Alice	7	0	-
28	강의 수강 신청	로그인 계정	0	0	-
29	Alice 수강 신청 취소	관리자, Alice	7	0	-
30	Bob 수강 승인	관리자	14	0	-
31	Bob 수료증 조회	관리자, Bob	7	0	-
32	Alice 행사 참가 등록	관리자, Alice	7	7	404: 7
33	Bob 행사 예약 취소	관리자, Bob	7	7	410: 7
34	Alice 결제 환불	관리자, Alice	7	0	-

허용 계정의 “모두”는 비로그인까지, “로그인 계정”은 관리자·Alice·Bob을 뜻합니다. 보류 404/410은 존재·삭제와 정상 차단의 구분이 불충분한 쓰기, 302는 이동 응답 확인이 필요한 조회입니다.

11 전체 기능 결과 · 35번부터 50번

개선 후 설정 조건의 계정별 대조입니다. 전체 오탐·미탐은 모두 0건이므로 표에는 정탐·보류를 표시합니다. 정탐의 근거는 읽기에서 자료 반환, 쓰기에서 저장 변경입니다.

번호	기능	허용 계정	정탐	보류	보류 HTTP: 건수
35	Bob 결제 청구서 조회	관리자, Bob	7	0	-
36	팀 A 비공개 문서 조회	관리자, Alice	7	0	-
37	팀 B 위키 편집	관리자, Bob	7	0	-
38	팀 A 구성원 초대	관리자, Alice	7	7	404: 7
39	팀 B 구성원 내보내기	관리자, Bob	7	7	410: 7
40	팀 A 보고서 내보내기	관리자, Alice	7	7	302: 7
41	Alice 첨부파일 등록	관리자, Alice	7	0	-
42	Bob 비공개 파일 다운로드	관리자, Bob	7	0	-
43	Alice 파일 공유 링크 생성	관리자, Alice	7	0	-
44	Bob 파일 공유 링크 폐기	관리자, Bob	7	7	404: 7
45	공동 프로젝트 보드 조회	Alice, Bob	7	0	-
46	관리자 사용 현황 조회	관리자	14	0	-
47	전체 회원 정보 내보내기	관리자	14	0	-
48	게시판 운영 역할 부여	관리자	14	0	-
49	Alice 문의 내용 조회	관리자, Alice	7	0	-
50	Bob 문의 완료 처리	관리자, Bob	7	7	404: 7

허용 계정의 “모두”는 비로그인까지, “로그인 계정”은 관리자·Alice·Bob을 뜻합니다. 보류 404/410은 존재·삭제와 정상 차단의 구분이 불충분한 쓰기, 302는 이동 응답 확인이 필요한 조회입니다.

전체 합계

정탐 392건 · 오탐 0건 · 미탐 0건 · 보류 91건

같은 기능의 여러 인증 조합을 합산한 대조 횟수입니다. 서로 다른 취약점 수가 아닙니다. 개별 계정·인증 조합·응답과 판정 사유는 account-results.csv에서 확인할 수 있습니다.